QAYRAWAN INFORMATION SYSTEMS

Data Protection Policy

ECC Compliance Program · Govern phase

Document ID	QIS-POL-001
Version	0.1 (Draft)
Date	7 November 2026
Classification	Internal
Prepared by	Naif Alsalem, GRC Lead

Language. This document is issued in Arabic and English. In case of conflict, the Arabic text prevails.

Fictional case study. Qayrawan Information Systems (QIS), its people and its clients are invented for a professional portfolio. Any resemblance to a real organization is unintended. The regulators and frameworks named are real.

Document control

Role	Job title	Name	Status
Owner	GRC Lead and Personal Data Protection Officer	Naif Alsalem	Complete
Reviewer	Chief Technology Officer	Reem Al-Otaibi	Pending
Endorsed by	Cybersecurity Steering Committee	—	Pending
Approver	Chief Executive Officer	Faisal Al-Harbi	Pending

Version history

Version	Date	Author	Change
0.1	7 Nov 2026	Naif Alsalem	First draft for review, translated from the Arabic lead text

Review cycle: Annually, or when relevant laws and regulations or QIS's services change, or after an incident affecting data.

Indicator colour key

Each clause of this policy carries key performance indicators (KPIs) that measure how its controls are applied, and key risk indicators (KRIs) for early warning. Their status is shown in these colours.

Colour	Status	Meaning and required action
Green	**On target**	Within the acceptable limit. Routine monitoring continues.
Amber	**Needs attention**	Approaching the acceptable limit. Requires follow-up and correction within the set period.
Red	**At risk or non-compliant**	Past the critical threshold. Requires immediate escalation to senior management and an urgent treatment plan.

1. Purpose

This policy protects the data that Qayrawan Information Systems owns or processes on behalf of its government clients, across its whole lifecycle: collection, processing, storage, transfer, sharing, retention and disposal, so that its confidentiality, integrity and availability are preserved.

Through it QIS meets the Personal Data Protection Law and its implementing regulation, the Essential Cybersecurity Controls (ECC-2:2024), the Data Cybersecurity Controls (DCC-1:2022), the National Data Management Office's standards, and its contractual commitments to clients.

2. Scope

- All data QIS owns or processes for Clients A to F, in any form, electronic or paper.

- All systems and assets in the program scope (QIS-PRF-001), including hosted systems and the citizen portal.
- All staff and contractors, and third parties with access to data, including the cloud provider.

3. Definitions

Term	Definition in this policy
Personal data	Any data that identifies or can single out an individual, such as citizen data in Client A's portal and student records at Client C.
Controller	The party that decides the purpose and means of processing personal data. For data QIS processes on a client's behalf, this is the government client.
Processor	The party that processes data for and on behalf of the controller. For the services it provides, this is QIS.
Classification levels	Top Secret, Secret, Restricted and Public, under the national data classification policy. For its own internal data, QIS applies the classification set in QIS-DCL-001.
Data masking	Replacing sensitive values with realistic but fictitious ones, for use in development and testing.
Data incident	Any actual or suspected unauthorized access to, disclosure, alteration or loss of data.

4. Policy clauses

4.1 Data classification and handling

1. Client data is classified under the client's own classification, and QIS data under QIS-DCL-001. No system holding Restricted data or above goes into use before its data classification is set.

2. These handling rules apply by classification level:

Level	Storage	Transfer	Sharing	Disposal
Top Secret and Secret	In the Kingdom, encrypted, on isolated systems with client approval	Encrypted, with the client's written approval	Not allowed without the controller's written approval	Secure destruction with a certificate
Restricted	In the Kingdom, encrypted at rest	Always encrypted	Only to those who need it for their work, under contract	Documented secure destruction
Public	No special restrictions	No special restrictions	Allowed	Normal deletion

Key performance indicators (KPIs)

Code	Indicator	Target	Frequency
KPI-01	Share of hosted systems with documented data classification	100%	Quarterly

Key risk indicators (KRIs)

Code	Indicator	Threshold	Frequency
KRI-01	Systems holding Restricted data or above without documented classification	Green: 0 Amber: 1 Red: 2 or more	Quarterly

4.2 Processing on client instructions

1. QIS processes client data only under the contract and the controller's documented instructions, and uses it for no other purpose.

2. Every client contract includes data processing terms covering purpose, scope, retention period, processing location, notification duties, and return and deletion at contract end.

3. QIS uses no other party to process a client's data without the client's prior written approval.

Key performance indicators (KPIs)

Code	Indicator	Target	Frequency
KPI-02	Share of client contracts with signed data processing terms	100%	Quarterly

Key risk indicators (KRIs)

Code	Indicator	Threshold	Frequency
KRI-02	Processing or sub-processing without documented client instruction or approval	Green: 0 Red: 1 or more	Quarterly

4.3 Personal data

1. Processing is limited to the minimum data needed for the stated purpose, and data is not kept longer than agreed.

2. QIS keeps a record of personal data processing activities for each client.

3. Data subject requests that reach QIS are passed to the controller within two working days, and QIS helps the controller meet them within the legal deadlines.

4. A data protection impact assessment is carried out before any major change to the citizen portal or any system processing personal data.

Key performance indicators (KPIs)

Code	Indicator	Target	Frequency
KPI-03	Share of data subject requests passed to the controller within two working days	100%	Monthly

Key risk indicators (KRIs)

Code	Indicator	Threshold	Frequency
KRI-03	Major changes to personal data systems made without an impact assessment	Green: 0 Red: 1 or more	Quarterly

4.4 Encryption

1. Data in transit over networks is encrypted with TLS 1.2 or later.

2. Restricted data and above is encrypted at rest. Encryption keys are managed under the national cryptography standards and kept separate from the data.

Key performance indicators (KPIs)

Code	Indicator	Target	Frequency
KPI-04	Share of hosted databases encrypted at rest	100%	Quarterly

Key risk indicators (KRIs)

Code	Indicator	Threshold	Frequency
KRI-04	Systems transferring client data unencrypted	Green: 0 Red: 1 or more	Monthly

4.5 Access to data

1. Access to client data is granted on need-to-know and least privilege, through individual accounts protected by multi-factor authentication.

2. Shared accounts must not be used to access client data. Access is reviewed quarterly and removed as soon as it is no longer needed.

Key performance indicators (KPIs)

Code	Indicator	Target	Frequency
KPI-05	Share of access reviews completed on time	100%	Quarterly

Key risk indicators (KRIs)

Code	Indicator	Threshold	Frequency
KRI-05	Shared or generic accounts with access to client data	Green: 0 Amber: 1 to 2 Red: 3 or more	Monthly

4.6 Data location and cloud

1. Client data is stored and processed only inside the Kingdom of Saudi Arabia, with a cloud provider licensed by the Communications, Space and Technology Commission.

2. Data is not transferred outside the Kingdom without the controller's written approval and in line with the Personal Data Protection Law and its regulations.

Key risk indicators (KRIs)

Code	Indicator	Threshold	Frequency
KRI-06	Client data storage locations outside the Kingdom	Green: 0 Red: 1 or more	Quarterly

4.7 Third parties and contractors

1. Cybersecurity requirements and confidentiality terms (NDA) are included in every contract with third parties and contractors who access data.

2. Contractors are security-screened before they are given access to client data or systems.

3. A third party must notify QIS immediately of any incident that may affect the data it processes.

4. When a contract ends, data is returned or destroyed, with evidence provided.

Key performance indicators (KPIs)

Code	Indicator	Target	Frequency
KPI-07a	Share of contractors who signed an NDA and passed screening	100%	Monthly
KPI-07b	Share of ended relationships with evidence of return or destruction	100%	Quarterly

Key risk indicators (KRIs)

Code	Indicator	Threshold	Frequency
KRI-07	Third parties or contractors accessing client data without a valid NDA	Green: 0 Amber: 1 Red: 2 or more	Monthly

4.8 Data in development and testing

Real personal data must not be used in development or testing environments; masked or synthetic data is used instead. The only exception is with written approval from the controller and the GRC Lead.

Key risk indicators (KRIs)

Code	Indicator	Threshold	Frequency
KRI-08	Non-production environments containing unmasked personal data	Green: 0 Red: 1 or more	Quarterly

4.9 Retention and secure disposal

1. Data is kept for the period set by contract or law, whichever is longer, then destroyed securely so it cannot be recovered.

2. Retired storage media are destroyed under a documented procedure, with a destruction certificate for Restricted data and above.

Key performance indicators (KPIs)

Code	Indicator	Target	Frequency
KPI-09	Share of destructions documented with a certificate	100%	Quarterly

4.10 Data leak prevention and incident reporting

1. Data loss prevention controls are applied to email and cloud storage.

2. Every employee and contractor reports any actual or suspected data incident immediately, under the Incident Response Plan (QIS-IRP-001).

3. QIS notifies the affected controller within 24 hours of discovering any incident affecting its data, so the controller can meet its legal notification duties.

Key risk indicators (KRIs)

Code	Indicator	Threshold	Frequency
KRI-10	Data incidents reported to the client more than 24 hours after discovery	Green: 0 Red: 1 or more	Per incident

4.11 Awareness

All staff and contractors complete data protection training when they join and every year after.

Key performance indicators (KPIs)

Code	Indicator	Target	Frequency
KPI-11	Share of staff and contractors who completed annual data protection training	95% or more	Quarterly

5. Roles and responsibilities

Role	Responsibilities
Chief Executive Officer	Approves the policy, provides the resources to apply it, and approves exceptions.
Cybersecurity Steering Committee	Endorses the policy, follows its indicators quarterly, and escalates red indicators.
GRC Lead (Personal Data Protection Officer)	Owns and updates the policy, monitors compliance, coordinates with controllers, and reports the indicators.
Chief Technology Officer	Applies the technical controls: encryption, access control, leak prevention and environment separation.
Head of Service Delivery	Applies the policy in managed services and makes sure shared accounts are not used at clients.
Chief Financial Officer	Includes data processing and confidentiality terms in contracts, screens contractors, and removes access when they leave.
Independent reviewer	Checks every year that the policy is applied and its controls are effective.
All staff and contractors	Follow the policy and report any data incident immediately.

6. Updates and review

The GRC Lead reviews this policy at least once a year, or when laws and regulations or QIS's services change, or after a major incident affecting data.

7. Compliance with the policy

1. The CEO monitors compliance with this policy through the indicator reports submitted to the Steering Committee.

2. The GRC Lead checks compliance with the policy periodically and records the results.

3. Any exception needs prior documented approval from the GRC Lead and the CEO, and must not conflict with legal or contractual requirements.

4. Breaching this policy may lead to disciplinary action under QIS's internal regulations.

8. References

Type	Reference	Issuer
Internal	QIS-PRF-001 Company Profile and Scope	QIS
Internal	QIS-DCL-001 Data Classification	QIS
Internal	QIS-RR-001 Risk Register (R-01, R-05, R-14)	QIS
Internal	QIS-IRP-001 Incident Response Plan	QIS
External	Personal Data Protection Law and its implementing regulation	SDAIA
External	Essential Cybersecurity Controls (ECC-2:2024)	National Cybersecurity Authority
External	Data Cybersecurity Controls (DCC-1:2022)	National Cybersecurity Authority
External	Data management, governance and personal data protection standards	National Data Management Office

9. Contact

For questions about this policy or to report a data incident: the Personal Data Protection Officer, at privacy@qis.example. Urgent incidents are reported immediately under the Incident Response Plan.